

Rethinking Identity Security in the Age of Deepfakes and Autonomous AI *(by Slam Laqtib)*

Abstract

The traditional ways we prove who we are online have reached a breaking point, leaving modern enterprises drowning in what we can call "Identity Debt." This paper dives into the dual-wave crisis currently transforming cyber risk. First, we have the rise of generative AI-driven deepfakes, which are actively compromising human biometric verification. Second, there is the explosion of autonomous AI agents, often called Non-Human Identities (NHIs), that are separating digital actions from actual human intent. By looking at high-profile heists, like the \$25 million Arup deepfake scam, and new vulnerabilities in AI workflows, this research points out a massive, growing gap in the "Identity of Action." Ultimately, this study argues that we need to move away from one-time, static logins and embrace a model of Continuous Verifiable Trust. To fix accountability in a world that is increasingly synthetic and autonomous, we explore key strategies like Identity Threat Detection and Response (ITDR), hardware-rooted security, and strict lifecycle governance for NHIs.

Keywords: Non-Human Identity (NHI), Deepfakes, Agentic AI, Identity Threat Detection and Response (ITDR), Continuous Verifiable Trust, Synthetic Reality, Identity of Action.

Introduction

Welcome to 2026, the era of "Identity Debt." We've reached a point where the traditional methods of proving who is actually sitting behind a keyboard, or executing a digital action, have largely collapsed. The cyber risk landscape isn't a simple binary of "human versus machine" anymore; it has blurred into a complex spectrum of synthetic reality.

For a long time, identity has been the bedrock of cybersecurity. Modern digital systems are built on a simple premise: verify who a user is, and then give them access to data, resources, and services. We've historically relied on things like passwords, multi-factor authentication (MFA), biometrics, and device checks to give organizations peace of mind that a user is who they claim to be. But artificial intelligence is turning those assumptions upside down.

Today, two massive technological waves are fundamentally rewriting the rules of identity security:

1. **The First Wave (Generative AI):** Attackers are using generative AI to create incredibly realistic deepfakes, easily impersonating real people through cloned voices, synthetic video, and hijacked biometrics.
2. **The Second Wave (Autonomous AI Agents):** We are seeing a massive surge in AI agents, or Non-Human Identities (NHIs), that perform tasks independently inside enterprise networks.

These agents are chatting with APIs, cloud platforms, and internal services, often using credentials that were originally meant for human beings.

When you put these two developments together, you get a brand-new class of cyber risk that impacts everyday people, massive corporations, and governments alike. The challenge isn't just figuring out if a human is real anymore; it's also about understanding, tracking, and controlling the autonomous systems acting on our behalf.

Identity Disruption from Generative AI and Autonomous Systems

The First Wave: Deepfakes and the Breakdown of Human Identity Verification

The Problem

Generative AI has made it shockingly easy to create synthetic media that looks and sounds exactly like a real person. Today's deepfake systems can spin up highly convincing video calls, audio messages, and images using only a tiny bit of training data. In the past, if we saw someone on video or heard their voice on the phone, we trusted it. But deepfakes make it incredibly hard to tell the difference between what's authentic and what's manufactured. Bottom line: organizations can no longer safely assume that seeing or hearing someone online means they are actually dealing with that person.

Cyber Risks to Society, Enterprises, and Governments

This explosion of deepfake tech is sparking a multidimensional crisis of trust, reshaping risks across several major sectors:

For Enterprises (Financial & Operational Risk): The biggest threat here is a highly evolved form of Business Email Compromise (BEC). Attackers are using synthetic audio and video to impersonate executives in live meetings or via urgent voice memos. They manipulate employees into transferring millions of dollars or handing over sensitive intellectual property. This goes way beyond traditional phishing because it weaponizes our natural, human instinct to trust our own eyes and ears, completely bypassing normal security guardrails.

For Governments (National Security Risk): On the global stage, "Diplomatic Deepfakes" are quickly becoming a favorite tool for state-sponsored disinformation. By faking videos or audio of world leaders, bad actors can stir up civil unrest, invent international crises, or mess with elections. We saw a stark preview of this during the 2024 New Hampshire primary, where an AI-generated robocall impersonating President Biden was deployed to suppress voter turnout. It was a wake-up call showing how easily cloned audio can threaten democratic institutions.

For Society (Trust Erosion): When we can no longer verify what is real, the public is pushed into a state of "post-truth" uncertainty. This skepticism chips away at the credibility of the media and the government.

It also creates a "Liar's Dividend", a scenario where actual bad actors can just dismiss real, damaging evidence against them by claiming "it was a deepfake."

Examples of Identity Abuse

To really grasp how severe this first wave is, let's look at a few real-world examples:

The \$25 Million Arup Heist (2024): A finance worker at the engineering firm Arup was invited to a video call. Everyone else on the screen, including the "CFO", was a deepfake. Tricked into believing he was taking orders from his actual leadership team, the employee transferred \$25.6 million to the attackers.

The Ferrari CEO Attempt (2024): Scammers targeted a Ferrari executive with a fake story about a secret acquisition, followed up by a phone call from a deepfake of CEO Benedetto Vigna. Fortunately, the executive noticed a slightly robotic tone in the "CEO's" accent and asked a personal question the AI couldn't answer, stopping the attack in its tracks.

Voice Cloning Scams: In one infamous case, attackers cloned a UK energy firm executive's voice to demand an urgent wire transfer, resulting in a loss of over \$200,000.

What do these attacks have in common? They bypassed millions of dollars worth of cybersecurity software by simply hacking human trust.

Implications, Detection Advances, and Regulatory Response

Thankfully, the good guys are fighting back. Researchers are building deepfake detection tools that use AI to spot tiny inconsistencies in facial movements, audio patterns, and hidden metadata. Microsoft and various universities have built tools that look for pixel-level glitches. Intel's *FakeCatcher* takes a fascinating biological approach, looking for the subtle changes in blood flow in facial pixels (photoplethysmography) that AI models can't easily fake yet. Meanwhile, ETH Zurich researchers have created microchips that cryptographically sign photos and videos the exact second they are captured, proving the media hasn't been tampered with.

Governments are stepping up, too. The EU AI Act and the U.S. National Policy Framework for AI (2026) are pushing for AI watermarks and regulating high-risk identity tech. Laws like the *TAKE IT DOWN Act* are specifically targeting the criminal use of non-consensual deepfakes.

In response, smart organizations are moving away from simple passwords and visual "liveness" checks (which are easily fooled by attackers injecting synthetic video directly into a camera feed). Instead, they are pivoting to hardware-backed security, like FIDO2 keys and decentralized identities. Visual and audio cues just aren't enough anymore in a zero-trust world.

The Second Wave: Autonomous AI Agents and Non-Human Identities

The Problem

If the first wave is about faking *who we are*, the second wave is about challenging *what we do*. We now have autonomous AI agents, like Microsoft Copilot, Salesforce Slackbot or custom internal bots, doing complex work for us. They draft legal documents, pull data, execute workflows, and even make financial trades. To pull this off, these agents need login credentials. Usually, they are handed "Service Accounts" with long-lasting passwords and massive permissions. As a result, companies have accidentally built a massive, hidden shadow workforce of Non-Human Identities (NHIs) that don't have human common sense, making them incredibly tempting targets for hackers.

Cyber Risks from Autonomous AI Agents

These autonomous systems introduce three big headaches:

1. **Privileged Access & Lateral Movement:** When an AI agent gets hacked, it becomes a "Confused Deputy." Because these bots often connect different systems (like pulling a file from AWS to post in Slack), a hacker who compromises one bot gets the keys to the entire kingdom.
2. **Expanded Attack Surface:** AI bots talk to the outside world. Malicious third-party websites can use "Indirect Prompt Injections" to trick a company's bot into scooping up sensitive internal data and sending it to a hacker.
3. **Accountability Risk:** It's a forensic nightmare. If an AI makes a terrible trade or deletes a database, who is to blame? Was it approved by a human? Was the bot hacked? Or did the AI just "hallucinate"?

Examples of Identity Abuse

To see what happens when the second wave hits, consider these scenarios:

Prompt Injection Attacks: Researchers have repeatedly shown how they can feed malicious, hidden text to an enterprise AI bot, tricking it into handing over company secrets.

The Claude Code Infiltration (2025): State-sponsored hackers targeted agentic workflows inside financial institutions. By slipping malicious instructions into the data the agents were reading, they tricked the bots into building secret backdoor accounts for the hackers.

ServiceNow & Langflow Vulnerabilities (2026): Critical bugs were found that let attackers hijack the "Identity of Action" in AI bots, bypassing security filters to run unauthorized, malicious code right in production environments.

Implications and Industry Response

The tech world is waking up to this. We are seeing a huge push toward machine identity management and strict Zero Trust architectures. OWASP has even released a "Top 10 for Agentic Applications (2026)" to

help security teams understand the threats. Companies like GitGuardian and Aembit are building tools to manage NHI lifecycles, treating a bot's identity like a digital passport that has to be constantly verified. Still, many companies are flying blind, with a massive governance gap regarding exactly how many AI agents are running loose on their networks.

The Convergence of Synthetic and Agentic Identity Risks

Here is the nightmare scenario: what happens when Wave 1 and Wave 2 crash into each other?

Imagine a hacker using a flawless deepfake to trick a system into authorizing a high-level task. That task is then automatically executed by a highly privileged AI agent. The result is a total breakdown in accountability. If you check the traditional audit logs later, everything looks perfect: a "verified executive" (the deepfake) gave an "authorized command" to a "legitimate bot" (the AI agent). You are left with a perfectly clean audit trail for a catastrophic breach. This is the ultimate "Identity Debt", a reality where it is physically impossible to figure out who actually did what.

Organizational Response and Security Controls

To survive this new landscape, businesses need to entirely rethink how they handle identity. Here is a breakdown of the modern security controls required:

Control Category	Security Measure	Tactical Consideration
Continuous Verification	Behavioral Biometrics	Monitor typing cadence, mouse movement, and session velocity to detect "non-human" or "hijacked" behavior throughout a session.
AI Governance	Agent-Specific IDs	Assign unique, short-lived identities to every single AI agent. Stop using shared or permanent service accounts.
Detection (ITDR)	Identity Threat Detection	Deploy platforms (like CrowdStrike Falcon Identity) to spot lateral movement and credential abuse in real-time.
Hardware Security	FIDO2 / Passkeys	Mandate hardware security keys (like YubiKeys) and Device Attestation to prove a physical, trusted device is actually present.

Human Oversight	Multi-Party Approval	For anything high-risk (like wire transfers over \$10k), require two-person "out-of-band" verification on an entirely different communication channel.
------------------------	----------------------	--

Strategic Implementation: People, Process, and Technology

Fixing this takes more than just buying new software. Organizations need to evolve their *People*, upgrading traditional "IAM Admins" into Identity Architects who actually understand AI risks and bot governance. For *Process*, companies must run strict, regular "Identity Audits" to delete old agents and strip away excessive permissions, while ensuring they have a literal "Kill Switch" for rogue bots. On the *Technology* front, the goal is shifting toward "Liveness-as-a-Service," using optical physics and behavioral cues rather than just looking at a picture to verify a human being.

Future Enhancements and Lessons for Organizations

Looking ahead, our resilience will rely heavily on decentralized identity frameworks and universally accepted content authenticity standards. We need regulators, tech giants, and security researchers to team up against synthetic threats. And, as always, education is paramount. Training everyday employees to spot the incredibly subtle signs of an AI impersonation remains our critical last line of defense.

Conclusion

The AI revolution has turned digital identity into a highly dynamic, synthetic battlefield. Deepfakes have shattered the reliability of human biometric verification, and autonomous AI agents have flooded our networks with a new, highly vulnerable class of non-human risk. If we want to maintain any level of trust and accountability in the digital world, we have to let go of the old "username and password" mindset. The future belongs to continuous verification, hardware-rooted trust, and relentless, rigorous governance over our AI agents.

Resources

- **Cybersecurity & Infrastructure Security Agency (CISA).** (2025). *Identity, Credential, and Access Management (ICAM) Reference Architecture*. U.S. Department of Homeland Security. [View CISA ICAM Framework](#)
- **European Union.** (2024). *Regulation (EU) 2024/1689 of the European Parliament and of the Council: The Artificial Intelligence Act*. Official Journal of the European Union. [View EU AI Act Official Text](#)
- **National Institute of Standards and Technology (NIST).** (2025). *Digital Identity Guidelines: Initial Public Draft (Special Publication 800-63-4)*. U.S. Department of Commerce. [View NIST SP 800-63-4](#)
- **Cloud Security Alliance (CSA).** (01/26/2026). [The State of Non-Human Identity and AI Security](#)
- **World Wide Web Consortium (W3C).** (2024). *Verifiable Credentials Data Model v2.0*. W3C Recommendation. [View W3C VC Data Model](#)
- **Gartner.** (2025). *Top Strategic Technology Trends: Emerging Tech: The Future of AI Security Is in Securing Agent Actions, Not Prompts*. [Requires Gartner login](#)

Expert Technical Summits & Media (Video/Audio)

- **Sapp, K.** (2025). *Securing Agentic AI: Identity Challenges & Solutions* [Video]. NHI Summit. [Watch on YouTube](#)
- **The CISO Signal.** (2024). *The \$25 Million Arup Deepfake: AI's Most Convincing Con* [Audio podcast episode]. YouTube Music. [Listen on YouTube Music](#)
- **Towers, M.** (2025). *Agentic AI and Non-Human Identity Risks* [Video]. NHI Summit. [Watch on YouTube](#)

Academic & Specialized Research

- AMP: Authentication of Media via Provenance hardware techniques and ledgers for media certification [AMP on arXiv](#).
- **Intel Labs.** (2024). *FakeCatcher: Real-Time Deepfake Detection via Photoplethysmography*. Intel Newsroom. [View Intel FakeCatcher](#)